Step 1: Research and breakdown

Role: Merchant onboarding (KYB) and compliance analyst **Industry:** Payment gateways and payment-instrument issuers in emerging markets (Ethiopia, licensed by the National Bank of Ethiopia)

1. Why this role

A payment gateway can only take money for a business after it has checked who that business is (know your business, KYB). It must also keep that check valid for as long as the merchant stays live. The analyst who does this sits on the critical path for revenue and for regulatory risk at the same time:

- Every day a merchant waits for approval is a day of payments the gateway doesn't process. Slow onboarding also drives applicants away.
- Every merchant approved by mistake is a risk of a fine or a lost licence.

I built the back office of a regulated Ethiopian payment gateway, including its onboarding queue, document matrix, risk tiers, sanctions screening, case management and daily compliance routines. So this breakdown comes from a workflow I've implemented, not only from desk research.

2. What the role does

The core of the job matches O*NET's *Compliance Officer* tasks: "evaluate applications, records, or documents to determine eligibility", "prepare reports of... decisions" and "report... violations to appropriate agencies" (O*NET 13-1041.00). In a payment gateway that means three jobs:

1. **Decide** whether a business may start taking payments (onboarding).
2. **Keep the decision valid** over time (ongoing monitoring).
3. **Detect and escalate** financial crime (investigations and suspicious-transaction reports).

The rules behind it:

- **FATF:** Recommendation 10 covers customer due diligence, including the ultimate beneficial owner, and Recommendation 24 covers beneficial-ownership transparency (FATF Recommendations).
- **Ethiopia:** payment-instrument issuers are licensed under NBE Directive ONPS/01/2020, which introduced tiered KYC (IFLR). It was amended in 2023, and a 2025 amendment reportedly requires real-time KYC and risk-based monitoring (Addis Insight).

A day in the role, as it runs at an Ethiopian payment gateway

When	What the analyst does
Morning	Works the onboarding queue, oldest first. For each application: checks the required documents for the merchant's legal form (sole trader vs share company), accepts or rejects each one with a note, and verifies the payout bank account.
Throughout	Screens the business and its owners against sanctions lists and the internal blacklist. Most hits are false positives that still need a written dismissal.

When	What the analyst does
Throughout	Sends information requests with due dates and chases merchants who don't reply.
Per application	Assigns a risk tier (low, medium, high or prohibited) with a rationale, lists what still blocks approval, and writes the decision. A second person approves (maker-checker).
Ongoing	Opens a case 30 days before a merchant's licence expires, runs periodic reviews every 6, 12 or 24 months by risk tier, rescreens merchants when sanctions lists change, and drafts suspicious-transaction reports for peer review and filing.

3. The cost of doing it by hand

Measure	Figure	Source
Cost of one corporate KYC review (banks)	**$2,598**, up from $2,211	Fenergo via CCI
Time for one corporate KYC review (banks)	**95 days**, up from 84	Fenergo
Manual merchant onboarding	**3–7 days**, vs minutes to hours when automated	Payabli (vendor)
Underwriting delayed by slow merchant replies	12–24 h, stretching to **5 business days**	Payrix
Applicants who abandon financial onboarding	**68%** (Europe), mainly because of time and the data asked for	Signicat via Fintech Times
False positives in name screening	**85–95%** (industry estimate)	FluxForce
Analyst salary (US median)	KYC analyst **~$65k**; compliance officer **$80,730**	Payscale, O*NET
Cost of getting it wrong	Starling Bank **£29M** (2024): onboarded 49,000 high-risk customers despite a restriction, and screened only after onboarding. Block / Cash App **$40M** to NYDFS (2025) for KYC/AML failures and a backlog of suspicious-activity reports.	King & Spalding, Banking Dive

Bank KYC figures (Fenergo) overstate merchant KYB, which is lighter. The other figures come from vendors or industry estimates, so read them as directional. Together they point the same way: the work is slow and expensive, about 9 in 10 of its alerts are noise, and mistakes are punished hard.

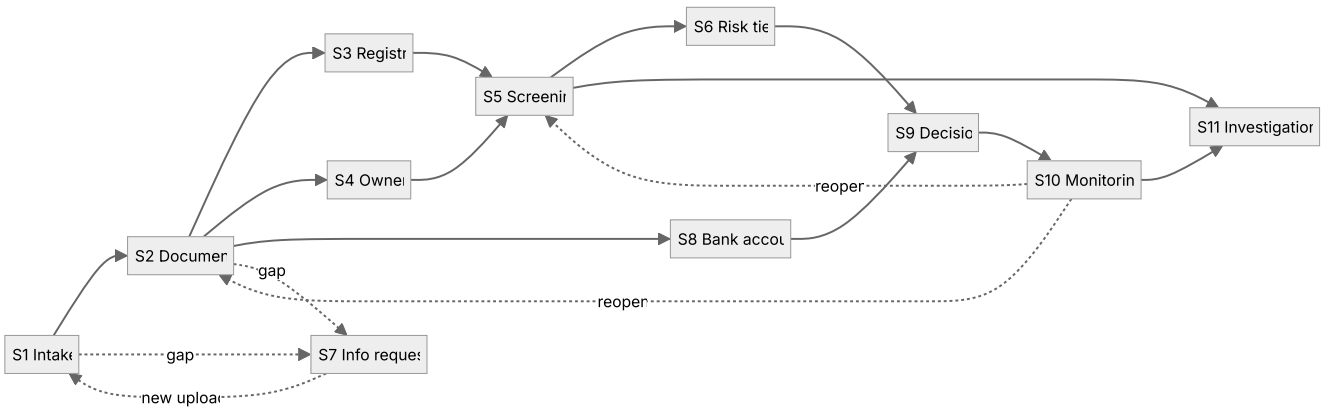
4. Sub-functions

Time shares are my estimates from running this workflow; no source publishes them.

#	Sub-function	Inputs → outputs	Frequency	Time share	Human must still own
S1	**Intake and completeness check** against the document matrix for the merchant's legal form	application, uploads → missing items, approval blockers	every application	10%	changes to the matrix
S2	**Document extraction and consistency** (trade licence, TIN, memorandum of association, owner IDs, expiry dates)	PDFs/images → structured fields, mismatches between documents and the form	every document	20%	authenticity of doubtful documents

#	Sub-function	Inputs → outputs	Frequency	Time share	Human must still own
S3	**Registry verification** (company register, LEI)	name, registration number → match or no match, registered officers	every business	8%	accepting a non-match
S4	**Owner and beneficial-owner identification**	memorandum, shareholder list → ownership tree	every business	8%	layered-ownership judgement
S5	**Sanctions, PEP and blacklist screening** with hit triage	names, dates of birth, countries → scored hits with a written rationale	every application and every list update	15%	confirming a true match
S6	**Risk classification** (category, geography, expected volume, structure)	S1–S5 results → tier and rationale	every application	7%	final tier; "prohibited" calls
S7	**Information requests and chasing**	gaps → emails, reminders, due dates	about half of applications	12%	tone in edge cases
S8	**Bank account verification**	bank letter, account name → match	every application	4%	none
S9	**Decision memo and approval**	S1–S8 → memo, approve or reject	every application	6%	**the approval itself** (maker-checker)
S10	**Ongoing monitoring**: documents expiring in 30 days, reviews every 6, 12 or 24 months, rescreening on list changes	merchant book, list changes → cases, renewal requests	daily	6%	closing reviews
S11	**Investigations and suspicious-transaction reports (STRs)**	alerts, linked payments → case, STR draft	rare	4%	**peer review and filing with the regulator**

Dependencies



- The onboarding path S1 → S2 → S3/S4 → S5 → S6 → S9 is the critical path. Everything downstream depends on S2, so extraction quality caps the quality of the whole agent.
- S7 is a loop: it starts whenever S1 or S2 finds a gap, and ends when the merchant uploads again.
- S10 is what turns a one-time decision into a continuous one. It feeds back into S2 (renewed documents) and S5 (rescreening).

5. Prioritization

Each sub-function is scored 1–5 on **value** (money or risk at stake), **frequency** and **automatability**. A score is the product of the three, so the maximum is 125.

Rank	Sub-function	Value	Freq.	Auto.	Score	Why
1	S2 Document extraction and consistency	5	5	4	**100**	The biggest time sink, on every document. A natural job for Gemini's document understanding.
1	S5 Screening and hit triage	5	5	4	**100**	Where fines happen. With 85–95% false positives, explaining why a hit is not a match saves the most analyst time.
1	S10 Ongoing monitoring	5	5	4	**100**	Runs daily, costs little, and is what regulators examine. It is also the agent's proactive side.
4	S6 Risk classification	4	5	4	80	Turns S1–S5 into one rationale a human can approve with one click.
5	S1 Intake and completeness	3	5	5	75	Rule-based and cheap. Must happen before S2.
5	S7 Information requests and chasing	5	3	5	75	Slow merchant replies are what stretch onboarding to days and drive the 68% drop-off.
7	S3 Registry verification	4	5	3	60	Strong where an open registry exists (LEI, UK). Ethiopia has no public registry API.
7	S9 Decision memo	4	5	3	60	The agent drafts the memo; a human makes the decision.
9	S4 Owner identification	4	5	2	40	Layered ownership needs human judgement.
10	S8 Bank account verification	3	5	2	30	Needs bank cooperation; no free API exists.
11	S11 Investigations and STRs	5	1	2	10	Rare, and filing is a legal act. Draft only.

What the agent should own

Scope	Sub-functions
The MVP agent owns	S1 + S2, S5, S6 + S9 (memo only, a human approves), S7, S10
Assistive	S3 (looked up through public registries where they exist), S4
Out of scope	S8, S11

The agent doesn't replace the analyst's accountability; regulators hold the institution responsible. It does all the preparation and follow-up, so **one analyst can clear a queue several times larger**, and the human time goes to the decisions only a person may make.

6. Free data sources and APIs (no card required)

API	Use	Terms, checked November 2026
Gemini API (Google AI Studio key)	S2 extraction, S5 hit triage, S6/S9 rationale, S7 drafting	Free tier on the Flash models, no billing needed. **Free-tier content is used to improve Google's products**, so the demo uses synthetic documents only. (pricing)
OFAC SDN and Consolidated lists	S5, S10	Free download, no key, with a delta archive for rescreening (OFAC)

API	Use	Terms, checked November 2026
UN Security Council Consolidated List	S5, S10	Free XML, no key. The download path must be re-checked before building. (UN)
GLEIF LEI API	S3	Free, no registration or key (GLEIF)
UK Companies House API	S3, S4 (officers and persons with significant control)	Free key, no card; 600 requests per 5 minutes (guidelines)
Gmail API	S7	Free for standard use; sending costs 100 of 6,000 units per user per minute (quota)
Google Calendar API	S7, S10 (due dates, review calls)	Free; 600 requests per user per minute (quota)
OpenSanctions *(not used)*	(S5)	Bulk data is CC BY-NC, and "compliance screening is a commercial use" even without revenue (terms). We use the official OFAC and UN lists instead.

Platform constraint: Google's documentation says "a Google Cloud billing account is required to access the Google Cloud Free Tier" (GCP), so Cloud Run, Cloud Scheduler and Cloud Functions are not available without a card. Firebase's Spark plan needs no payment method and includes Firestore and Hosting (Firebase). Step 2 chooses the hosting and scheduler within this constraint.

7. Risks and caveats

- **No Ethiopian registry API.** Trade-licence and TIN checks against government systems stay manual, or are simulated in the demo. S3 uses GLEIF and Companies House where they apply.
- **Synthetic data only.** Real merchant documents never go to the Gemini free tier.
- **Human accountability.** The agent recommends, drafts and chases. A human approves merchants, confirms true sanctions matches and files STRs.
- **Soft numbers.** The figures from vendors and industry estimates are labelled as such. Re-check API quotas before the demo, because Google plans overage billing on Workspace APIs later in 2026.

Step 2: Solution design

Product: Wekil (ወኪል, Amharic for "agent" or "representative"), an AI KYB and compliance analyst for payment gateways **Author:** Abenezer Alebachew · **Status:** draft for review · **Research:** Step 1

1. Role and why

Role: Merchant onboarding (KYB) and compliance analyst at a payment gateway licensed by the National Bank of Ethiopia.

Why this role:

- **It sits on the revenue path and the regulatory path at once.** A merchant can't take a single payment until KYB is done, and a wrong approval can cost a licence.
- **The manual cost is high and well documented:**
  - a corporate KYC review costs $2,598 and takes 95 days at banks;
  - merchant onboarding takes 3–7 days by hand;
  - 68% of applicants abandon onboarding;
  - 85–95% of sanctions-screening hits are false positives;
  - recent fines include Starling Bank's £29M and Cash App's $40M.

  Sources are in Step 1 §3.
- **The work suits an AI agent.** Most of the time goes on reading documents, comparing names, writing rationales and chasing people. Gemini does these well; the hard decisions stay with a human.
- **I've built this workflow before.** I built the back office of a regulated Ethiopian payment gateway: onboarding queue, document matrix, risk tiers, sanctions screening, maker-checker approvals and daily compliance routines. Wekil automates the analyst who works in such a system.

Value proposition:

	Without Wekil	With Wekil
Time from complete application to decision	days of manual review	minutes
Analyst's job	prepares every file and chases every merchant	reviews a ready memo and makes the decision
Sanctions hits	each one dismissed by hand	each comes with a written triage
Monitoring (expiring documents, periodic reviews, rescreening)	depends on someone remembering	runs every morning

2. What the agent handles

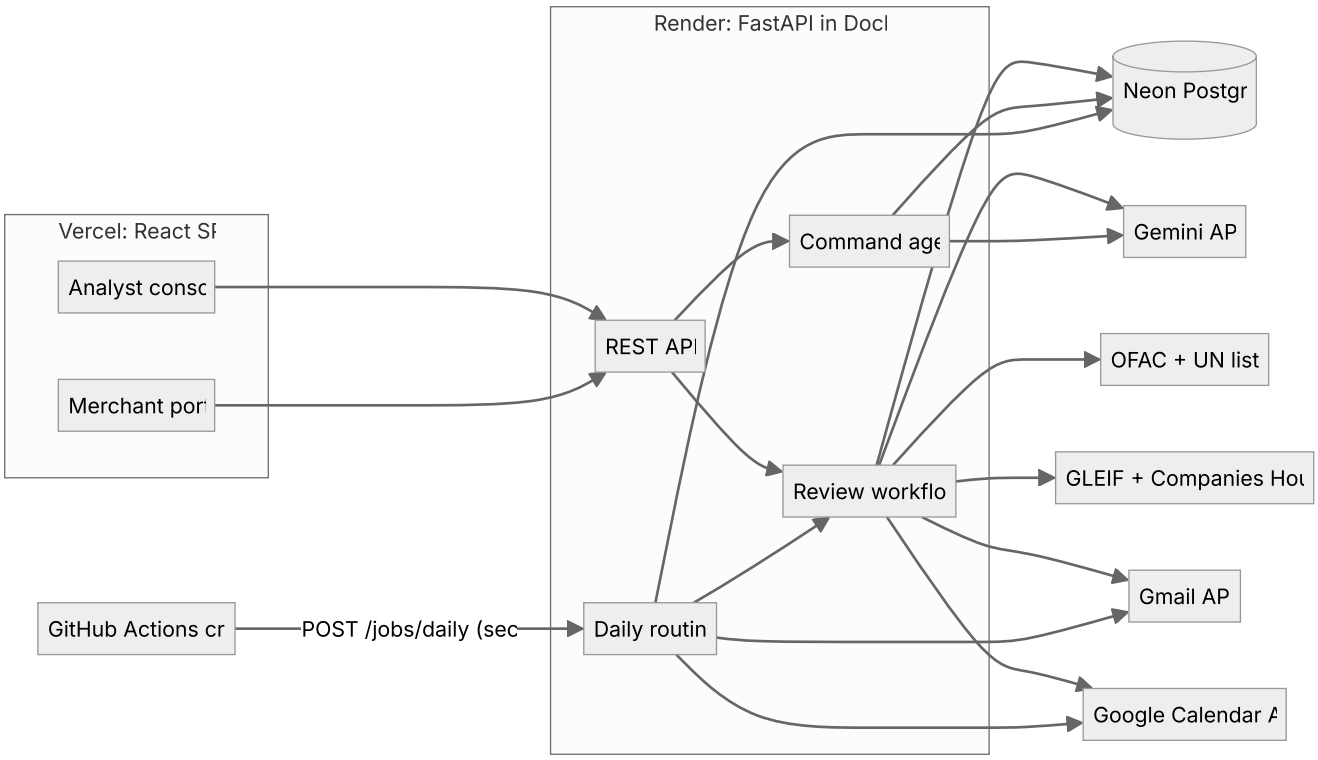
These are the high-priority sub-functions from Step 1 §5.

#	Workflow	Agent action	Human role
S1	**Intake and completeness**	Checks the uploads against the required-documents matrix for the merchant's legal form (sole trader, PLC, share company) and lists approval blockers.	Maintains the matrix
S2	**Document extraction and consistency**	Gemini reads each PDF or image (trade licence, TIN certificate, memorandum of association, owner ID) into structured fields. Code then compares the fields across documents and against the form: names, numbers, owners, expiry dates.	Judges doubtful documents
S3	**Registry lookup**	Searches GLEIF (LEI) and UK Companies House for foreign or UK entities. Ethiopian entities go through a simulated registry, because no public API exists.	Accepts a non-match
S5	**Sanctions screening and triage**	Code fuzzy-matches the business and owner names against the official OFAC and UN lists. For each candidate hit, Gemini compares the evidence (date of birth, nationality, address, entity type) and writes "likely the same / likely not the same" with its reasons.	Confirms a true match
S6 + S9	**Risk tier and decision memo**	A rule-based score (category, country, ownership, hits, mismatches, expected volume) gives a tier of low, medium, high or prohibited. Gemini writes a one-page memo explaining the result.	**Approves or rejects** (maker-checker: the agent prepares, a human decides)
S7	**Information requests and chasing**	Emails the merchant through Gmail with a single-use upload link and a due date, puts the due date on the compliance Google Calendar, reads the merchant's reply, sends reminders, then escalates. When new documents arrive, it re-runs the review.	Handles edge cases
S10	**Ongoing monitoring (proactive)**	Every morning: refreshes the sanctions lists and rescreens approved merchants against new entries, opens renewal cases 30 days before documents expire, opens periodic reviews (every 6, 12 or 24 months by tier), chases overdue requests, and emails the analyst a digest.	Closes the cases

Deliberately out of scope:

- **S8, bank account verification:** there's no free API for it.
- **S11, suspicious-transaction reports (STRs):** filing is a legal act, so the agent never files one.
- **S4, beneficial-owner trees:** the agent shows owners and officers but doesn't decide ultimate ownership.

3. Architecture



Layer	Choice	Why
Frontend	React + Vite + TypeScript on **Vercel** (Hobby)	A responsive single-page app with two areas: the analyst console and the merchant portal. Free, no card.
Backend	**FastAPI** in Docker on **Render** (free web service)	Typed API and a long-running container, so a review can run in the background after an upload. Free, no card; sleeps after 15 minutes idle.
Database	**Neon** Postgres (free)	Relational data suits applications, cases and an append-only audit log. Documents are stored as binary data, since the demo files are small. Free, no card, no expiry.
Scheduler	**GitHub Actions** cron, 06:00 Addis Ababa time	Stands in for Cloud Scheduler, which needs billing. It calls a protected endpoint, lives in the repo, and also wakes the Render service.
AI	**Gemini** through a Google AI Studio key (`gemini-3.8-flash` , configurable)	Reads PDFs and images, returns output in a fixed JSON schema and supports function calling. Free tier.

Why not GCP hosting: Google's docs say "a Google Cloud billing account is required to access the Google Cloud Free Tier". Cloud Run, Cloud Scheduler and Cloud Functions therefore need a card, and Firebase Storage has needed the Blaze plan since October 2024. Wekil keeps the GCP services that work without billing: the Gemini API (AI Studio key), and the OAuth client for Gmail and Calendar in a GCP project with no billing. The rest runs on platforms that need no card. The swap is small: the backend is a container, so moving it to Cloud Run is a redeploy, and the cron becomes a Cloud Scheduler job.

Backend modules (one file per concern)

```
backend/app/
  main.py          FastAPI app, routers, CORS
  db.py            SQLAlchemy models + session
  workflow.py      the per-application review state machine (S1→S2→S3→S5→S6/S9, S7 loop)
  commands.py      the command bar: Gemini function calling over a small tool registry
  routine.py       daily routine (S10 + chasing + digest)
  tools/
    gemini.py      one helper: prompt + schema → validated object
    documents.py   extraction schemas per document type, consistency checks
    screening.py   sanctions list loader/differ, fuzzy candidates, Gemini triage
    registry.py    GLEIF, Companies House, simulated Ethiopian registry
    risk.py        scoring rules → tier, memo
    mail.py        Gmail send / read replies (thread-aware)
    calendar.py    due-date and review events
  api/             analyst.py, merchant.py, jobs.py (thin routers)
```

The external tools are plain functions with typed inputs and outputs. The review workflow and the command agent call the same functions, so every capability exists once.

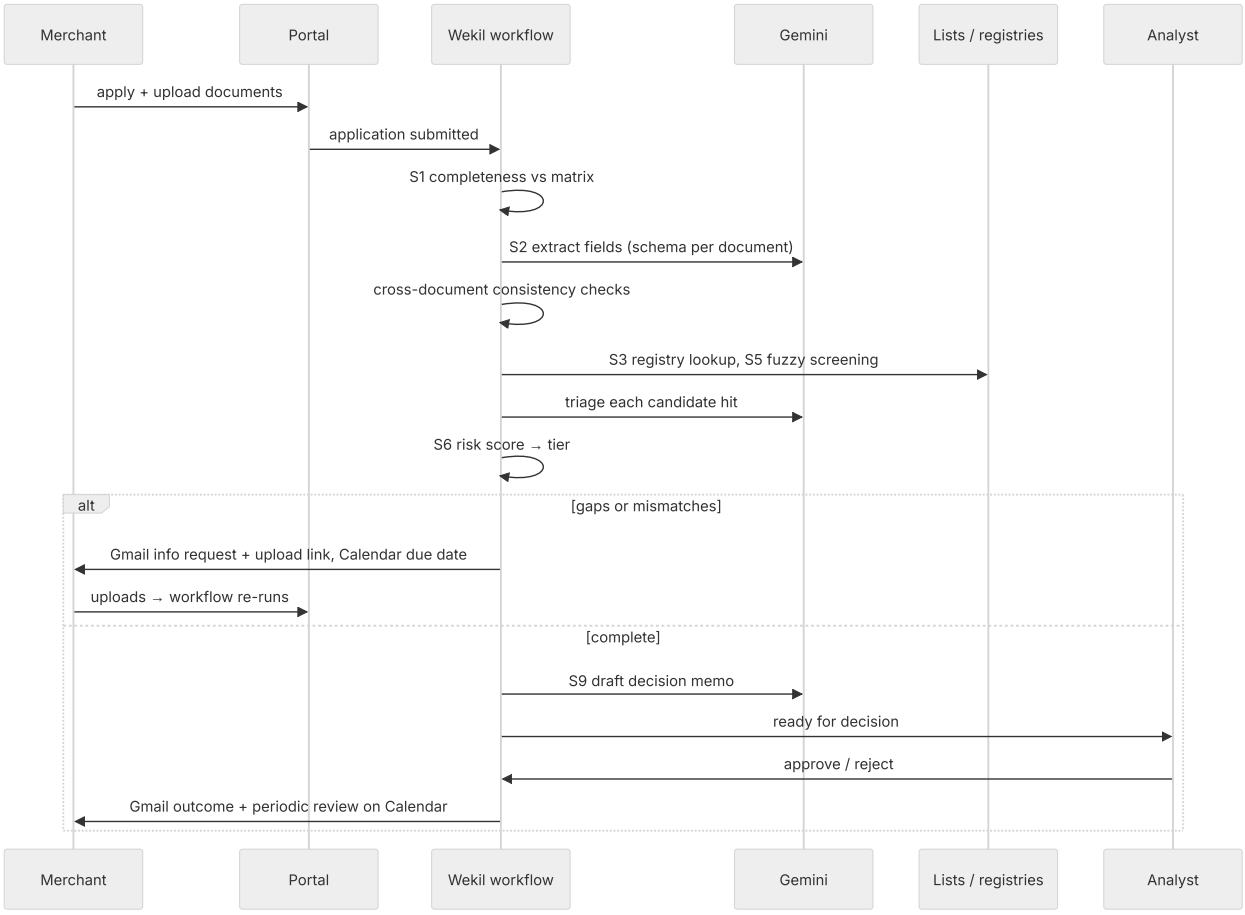
Frontend

Screen	Purpose
Today	What the agent did overnight, decisions waiting for a human, overdue requests, cases due
Queue	Applications by status (reviewing, awaiting merchant, ready for decision, approved, rejected), oldest first
Application workspace	One screen per merchant: documents side by side with extracted fields (mismatches highlighted), registry result, sanctions hits with triage, risk tier, memo, and a timeline of every agent and human action. Buttons: approve, reject, request information.
Monitoring	Approved merchants, expiry dates, next review, latest rescreen
Command bar (on every screen, ⌘K)	Plain-English requests. Actions that write anything (emails, scheduling) are shown as a proposed plan and run only after the analyst confirms.
Merchant portal	`/apply` (business details + documents) and `/upload/:token` (answer an information request). Works on a phone, no account needed.

Design direction: a distinctive, compliance-desk look that doesn't look like a generic AI dashboard, built with the repo's design skills (frontend-design, impeccable, ui-ux-pro-max). It must be responsive down to phone width, because merchants in Ethiopia apply mostly from phones.

4. How the agent acts

Onboarding (event-driven)



Every morning (proactive)

The GitHub Actions cron calls `POST /jobs/daily`, and the routine:

1. Downloads the OFAC and UN lists, compares them with yesterday's copy, and screens every approved merchant against **new entries only**.
2. Opens a renewal case for every document expiring within 30 days and emails the merchant an upload link.
3. Opens periodic reviews that fall due (every 6, 12 or 24 months by tier).
4. Sends reminders for overdue information requests (a firmer tone each time) and flags requests that stay unanswered after the second reminder.
5. Reads merchant replies in Gmail threads. Gemini classifies each one (documents coming, question, refusal) and records it on the timeline.
6. Emails the analyst a digest of today's decisions and cases.

Command bar

The command agent uses Gemini function calling over these tools:

- `search_applications`
- `explain_risk`
- `send_reminders`

- `screen_name`
- `schedule_review`
- `summarize_queue`

Examples:

- "Which applications are waiting on merchants for more than 3 days? Chase them."
- "Why is Tana Spice Traders high risk?"
- "Screen 'Blue Horizon Trading' against sanctions."

5. Third-party APIs and free-tier limits

Integration	Used for	Free terms (checked Nov 2026)	Expected use
Gemini API	extraction, triage, memo, email drafting, commands	AI Studio free tier, no billing	about 10 requests per application
Gmail API	requests, reminders, outcomes, digest; reading replies	free; sending costs 100 of 6,000 units per user per minute	under 50 a day
Google Calendar API	due dates, review events	free; 600 requests per user per minute	under 50 a day
OFAC SDN / Consolidated lists	screening	free download, no key	once a day
UN Security Council Consolidated List	screening	free XML, no key	once a day
GLEIF LEI API	registry (global entities)	free, no key	per application
UK Companies House API	registry and officers (UK entities)	free key; 600 requests per 5 minutes	per application
Render / Vercel / Neon / GitHub Actions	hosting, data, scheduler	free plans, no card	within limits

OpenSanctions is deliberately not used: its terms treat compliance screening as commercial use.

6. Data model

Table	Holds
`merchants`	profile, legal form, category, country, tier, status, next review date
`documents`	type, file bytes, extracted fields (JSON), expiry date, status
`screening_hits`	the name matched, the list entry, similarity score, Gemini verdict and reasons, analyst decision
`requests`	information requests: items, due date, token, Gmail thread id, reminder count
`cases`	renewal, periodic review, rescreen hit; owner, due date, status
`events`	append-only audit timeline: actor (agent or analyst), action, before/after values
`list_entries`	normalised OFAC and UN entries, with the date each was first seen (used for the daily diff)

7. Safety and compliance

- **Humans decide.** The agent never approves, never confirms a true sanctions match and never files anything. It prepares, recommends and follows up.

- **Arithmetic and matching are code; judgement is Gemini.** Fuzzy matching, scores and dates are computed in code, so they can be reproduced. Gemini only reads documents, explains and writes text, and its output must fit a fixed JSON schema.
- **Text inside documents can't steer the agent.** Document and email content is passed to Gemini as data. Gemini never chooses an email recipient or what to do next: the workflow does, and emails go only to the merchant on file.
- **Audit trail.** Every agent and human action is written to `events`, and no endpoint updates or deletes those rows.
- **Data.** The demo uses synthetic merchants and documents only, because the Gemini free tier may use inputs to improve Google's products. Upload links are signed and expire after 7 days. Secrets are stored as environment variables.

8. Demo scenario (synthetic data)

1. **A clean sole trader** applies from a phone. Within a minute it's "ready for decision", with a memo. The analyst approves, the merchant gets an email, and a periodic review appears on the calendar.
2. **A share company whose memorandum lists an owner missing from the form**, and whose licence expires in 3 weeks. The agent emails an information request, the merchant uploads, and the agent re-reviews it automatically.
3. **A name close to a sanctions-list entry.** The agent shows the candidate hit and explains why it's likely not the same entity (different date of birth, nationality and entity type). The analyst confirms.
4. **The morning routine** is triggered from GitHub Actions: a new list entry matches an approved merchant, a document is about to expire, and a request is overdue. The cases, reminder emails and digest appear live.
5. **The command bar:** "Chase everyone who's been waiting over 3 days" → proposed plan → confirm → emails sent.

9. Delivery plan

#	Milestone	Done when
1	Repo skeleton, database, deploy pipeline	an empty app is live on Render and Vercel, connected to Neon
2	Intake, extraction and consistency (S1, S2)	an upload produces extracted fields and mismatches
3	Screening, registry, risk and memo (S3, S5, S6, S9)	the workspace shows hits with triage, a tier and a memo
4	Gmail, Calendar and the request loop (S7)	the request → upload → re-review loop works end to end
5	Daily routine and GitHub cron (S10)	the scheduled run creates cases, sends reminders and the digest
6	Command bar, UI polish, responsive pass	all demo scenarios pass on desktop and mobile
7	Tests, README, demo video	submitted to kidus@brain3.ai

10. Risks and assumptions

Risk	Mitigation
No public Ethiopian company-registry API	Clearly labelled simulated adapter; GLEIF and Companies House are real
Gemini free-tier limits change or are hit	Model and rate limits are configurable; ~10 requests per application; retries with backoff
Render sleeps after 15 minutes idle	The cron wakes it; warm it up before demos
Gmail OAuth refresh token expires after 7 days while the OAuth app is in testing mode	Re-authorise before the demo and document this in the README
Gemini makes a wrong call on a document or hit	Every verdict shows its evidence, a human decides, and all actions are audited